

Проектирование системы контроля доступа

Основные требования к механизму КД

1. Блокировать доступ тем сотрудникам, которые не обладают правами
2. Разрешать доступ тем сотрудникам, кто наделен соответствующими привилегиями
3. Ведение журнала статистики и событий, происходящих внутри системы
4. Реакция на инциденты (уведомление администратора, блокировка ресурса, учётной записи, рабочей станции, ...)
5. Проведение идентификации и аутентификации пользователей в системе
6. Контроль целостности системы разграничения доступа (изолированность МБО)

Основные проблемы

1. Наличие избыточных прав доступа
2. Наличие избыточности в механизме контроля доступа (невозможности получить права)
 - Пункты 1-2 проверяются при разработке системы
 - Можно смоделировать деятельность сотрудника и проверить, какие доступы не будут задействованы, а какие столкнутся с ограничением прав
 - фаззинг, мониторинг рабочих процессов, проработка сценариев
 - формальная верификация
3. Отсутствие необходимых согласований или избыточное согласование в процессе управления доступом
 - Требование согласовывать выдачу прав замедляет бизнес-процессы
 - Большое количество бюрократии и регулярное согласование изменения прав ведёт к ошибкам со стороны администратора и уязвимостям в системе

Основные проблемы (2)

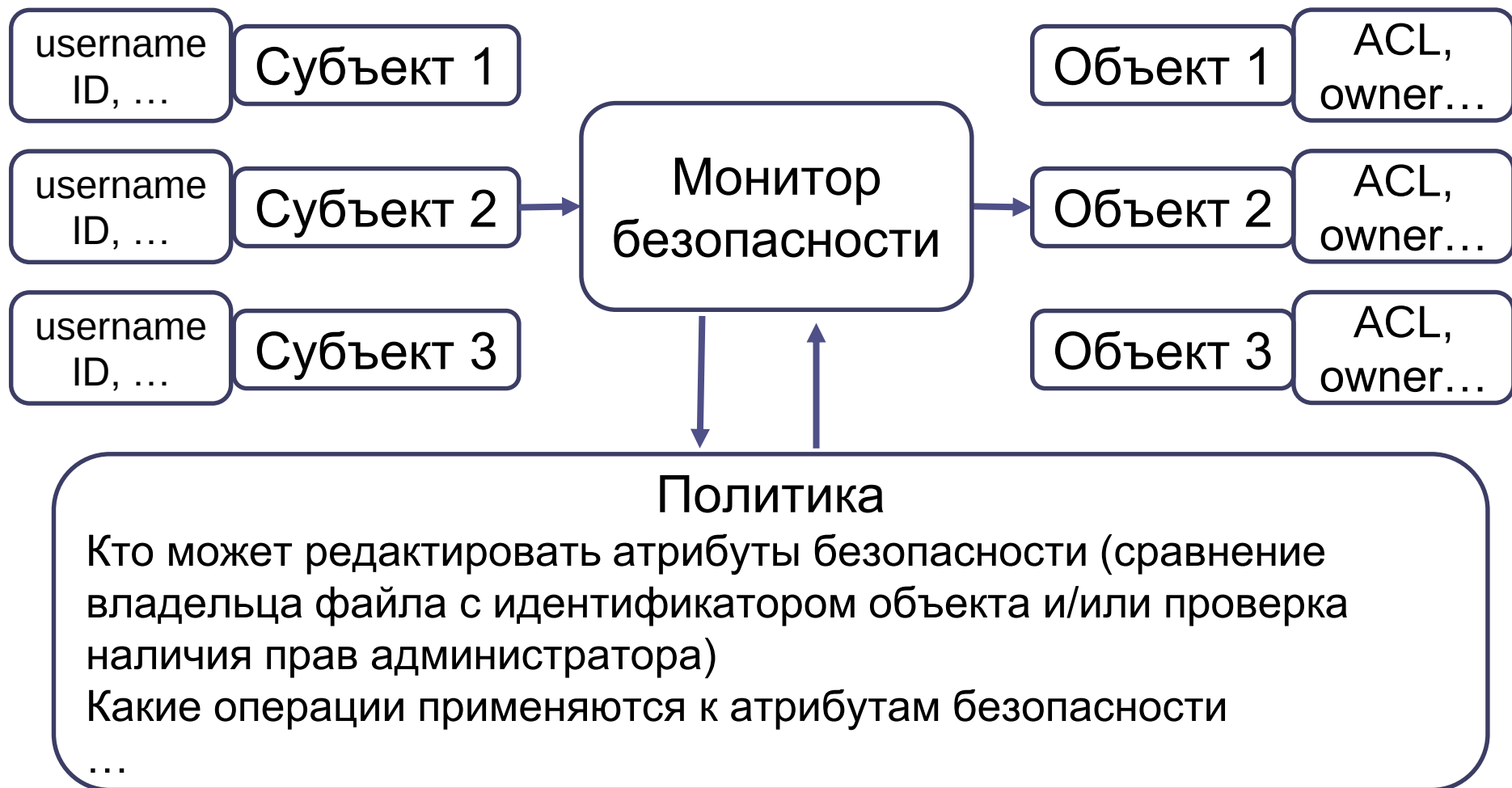
4. Плохая масштабируемость

- RBAC легко масштабируются к изменению числа пользователей, но трудно к изменению инфраструктуры (приходится переписывать роли); иногда решается использованием прав на рубрики (типы), а не объекты
- DAC требует много внимания со стороны администратора при добавлении сущностей (частично решается правильно спроектированными группами), не позволяет защитить систему от утечек
- MAC делает DAC безопаснее, позволяет систематизировать объекты
- ABAC легко масштабируется и позволяет реализовать сложную политику доступа, трудно проектируется

Дискреционная политика

атрибуты субъектов
(учётных записей)

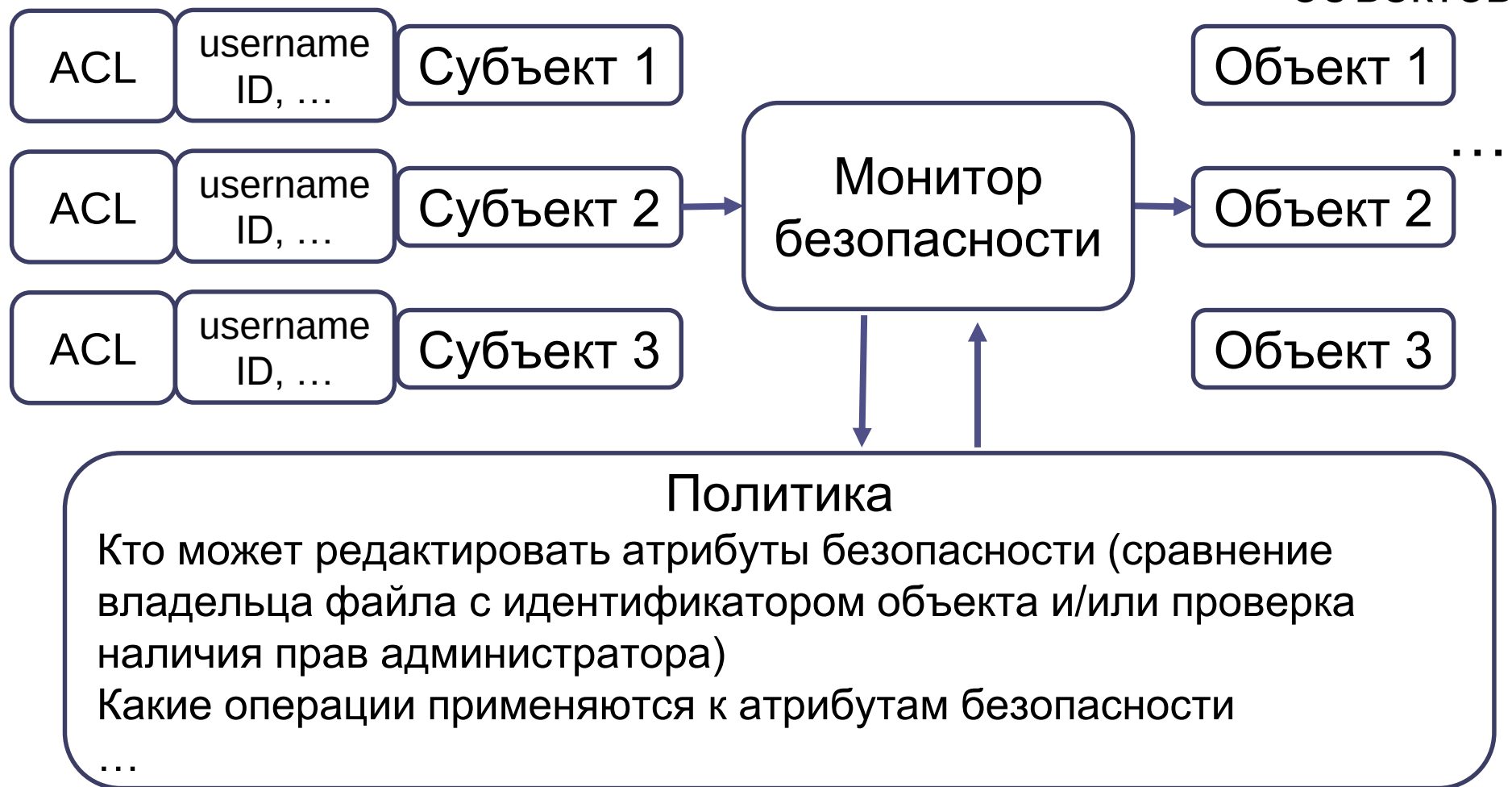
атрибуты
объектов



Дискреционная политика (2)

атрибуты субъектов
(учётных записей)

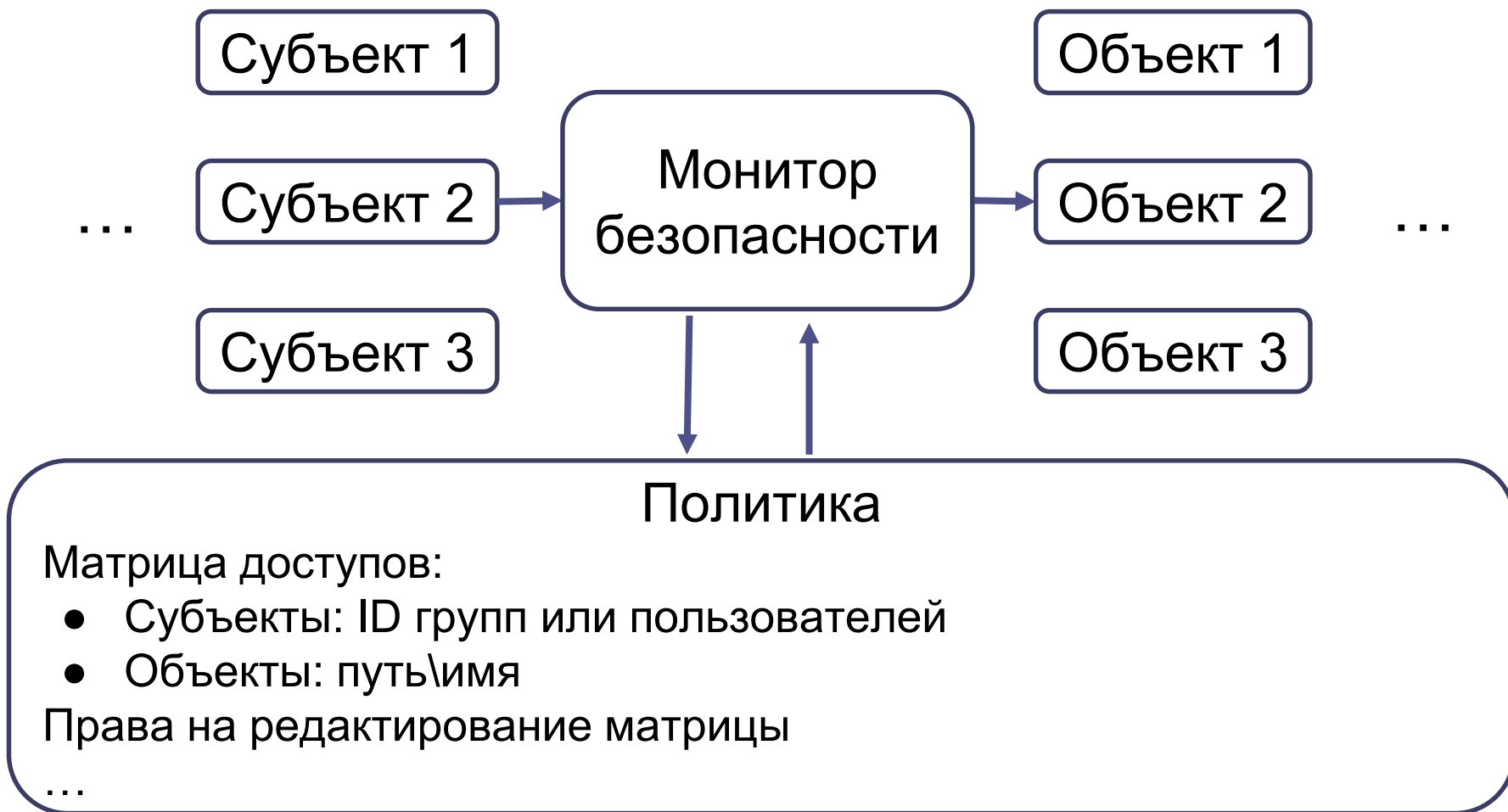
атрибуты
объектов



Дискреционная политика (3)

атрибуты субъектов
(учётных записей)

атрибуты
объектов



Субъект и объект должны быть идентифицированы

- Учётная запись с уникальным идентификатором
- Сертификаты, токены
- Путь к файлу + имя файла
- Атрибуты подключения: MAC/IP, доменное имя...
- ...

Примеры хранения данных (зависят от системы)

- ACL, метки конфиденциальности хранятся в ОС как атрибуты файла (для объекта) или учётной записи (для субъекта); доступ к файлу и его ACL (атрибут файла) – разные вещи
- Сертификаты/токены выдаются пользователям сервером аутентификации и используются для получения доступа к сервисам и их ресурсам внутри инфраструктуры; IGA (Identity Governance and Administration) и IDM (Identity Management) системы (управление доступом в инфраструктуре)

Форма хранения политики

Форма

- БД
- XML
- JSON
- txt ...

Место

- Защищенная область диска
- Выделенный сервер

Политика изолируется от всех, кроме администратора

Если не только админ может модифицировать политику, то формируется специальный скрипт для предоставления доступа с админскими правами

Фундаментальные для системы правила могут непосредственно внедряться в код программы

Тип запроса

Монитор безопасности определяет тип запроса

- На чтение
При открытии файла/директории
- На запись
При попытке сохранения изменений в файл/директорию
- Исполнение
При попытке создания процесса

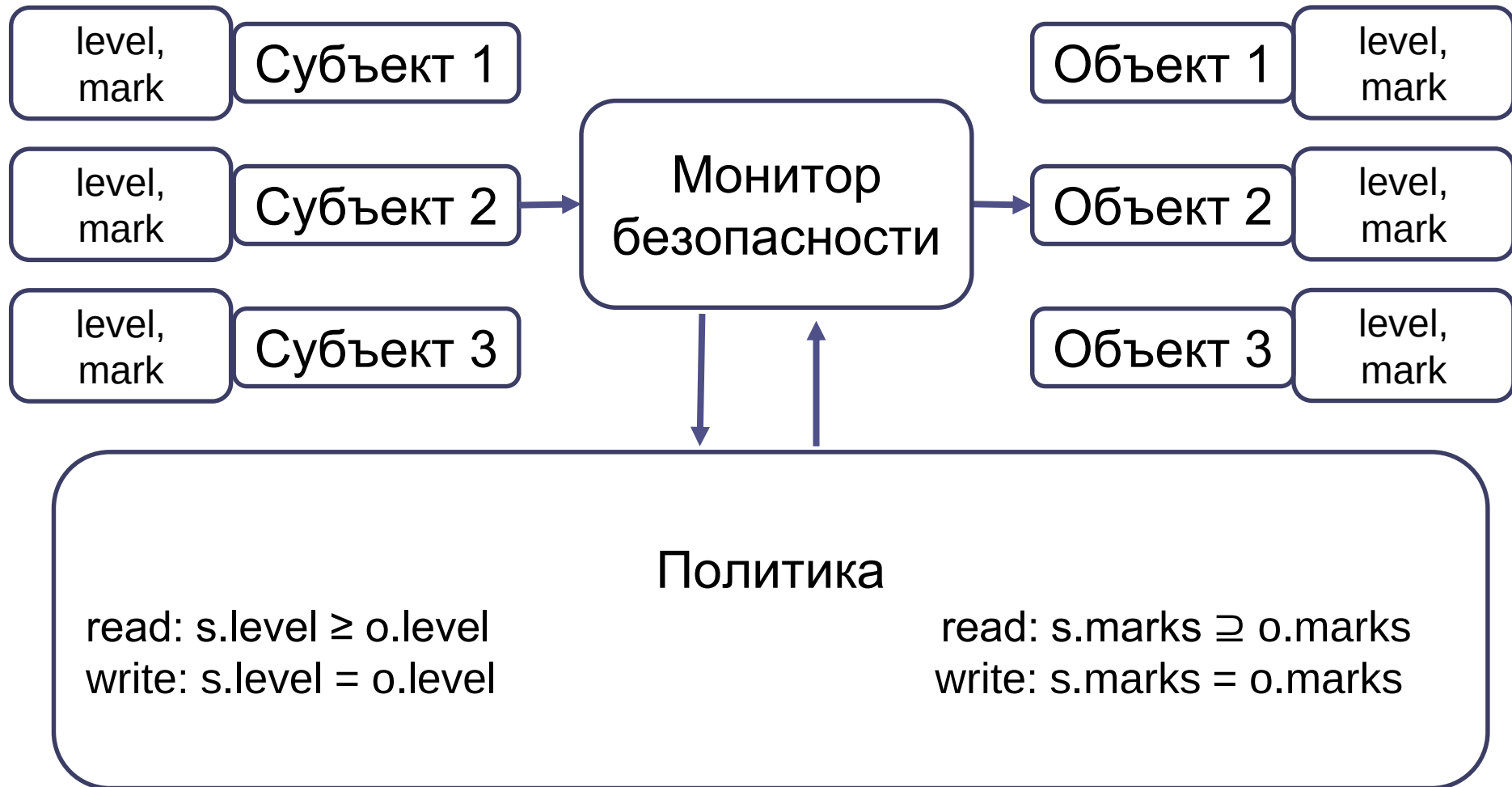
Абстрактные права извлекаются из запроса (SQL, HTTP, ...)

- Могут быть разбиты на атомарные запросы (чтение/запись строк, ...)
- Могут быть удовлетворены частично (извлечение только части таблицы, отображение только части информации с сервера)

Мандатная политика

атрибуты субъектов
(учётных записей)

атрибуты
объектов



Ролевая политика

Users			
username	password	ID	year
Alice	qwe	1	1990
Bob	11111	2	2000
Tom	123	3	2010

Roles		
U_ID	Role	constraints
1	admin	000000
3	teacher	010101
2	student	010111

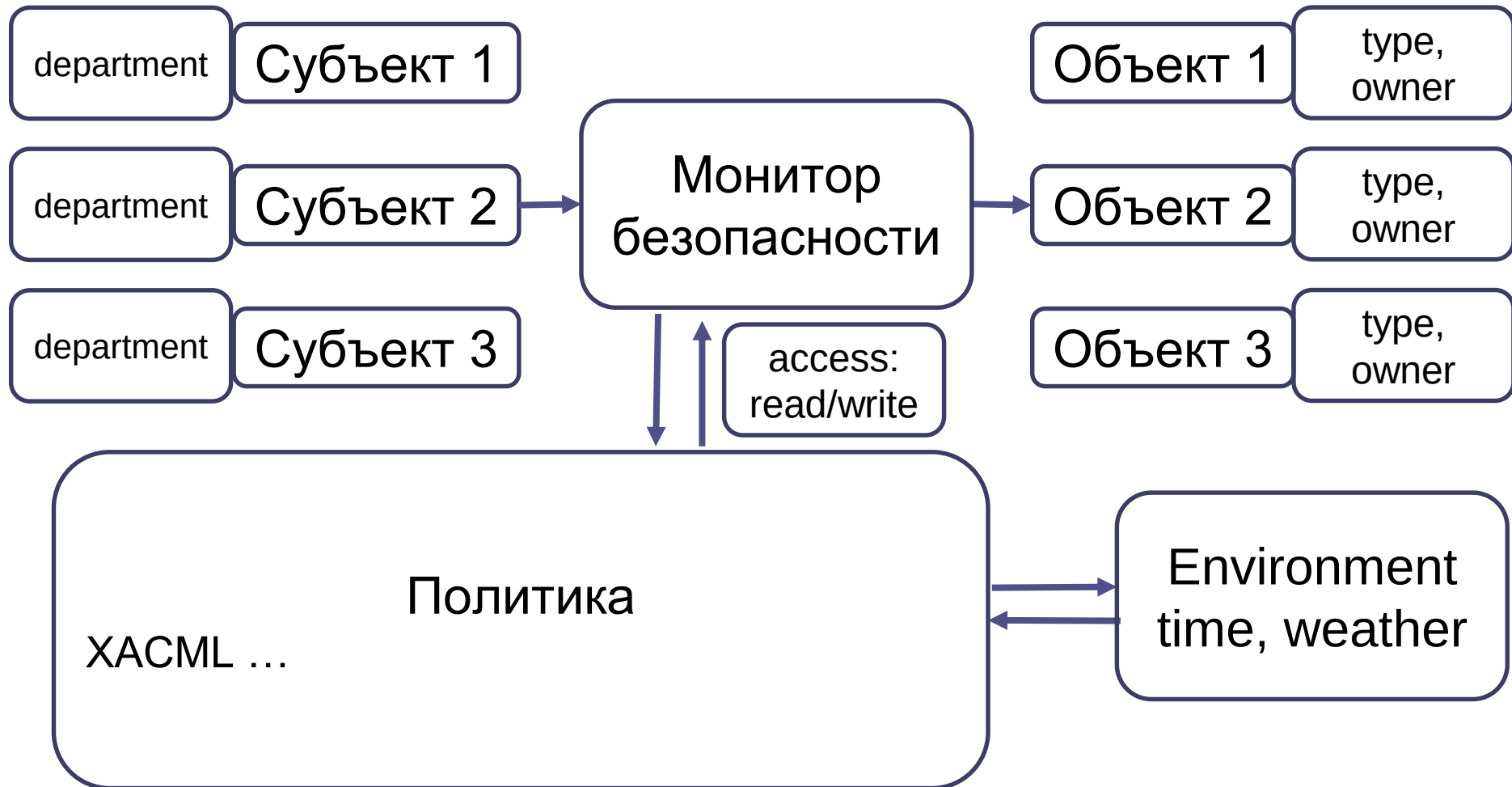
Privilege		
Role	right	object
admin	read	file1
teacher	writer	file 2
student	exec	file 3

...

Атрибутная политика

атрибуты субъектов
(учётных записей)

атрибуты
объектов



Сессия

Если пользователю доступны несколько уровней решётки конфиденциальности, различные тематические рубрики или несколько ролей, то их использование в рамках одной сессии может привести к нарушению политики

Например: перенос информации вниз с понижением уровня

Решения:

- Неизменности параметров авторизации (уровня, роли, ...) в рамках сессии; сессия – взаимодействие с системой между входом в учётную запись и выходом из неё
- Создание отдельных учётных записей разных параметров авторизации (уровня, роли ...)

Обновление политики также обычно сопровождается сбросом всех текущих сессий

Проверка системы КД

Тестирование

- написание тестовых сценариев для всех функций системы
- полнота?

Мониторинг

построение **модели** (спецификации) политики безопасности и анализ поведения системы в контролируемой среде

Формальное доказательство

- проверка свойств безопасности на модели системы контроля доступа
- соответствует ли модель реализации?

Общая методология

Заказчик

Пользователь (клиент)

Законодательство

Политика
безопасности

ACL

Решётка уровней

Роли ...

Механизм управления
доступом

Конфиденциальность

Целостность

Формальная
модель

Достижимость
небезопасных состояний
Запрет потоков на запись
вниз ...

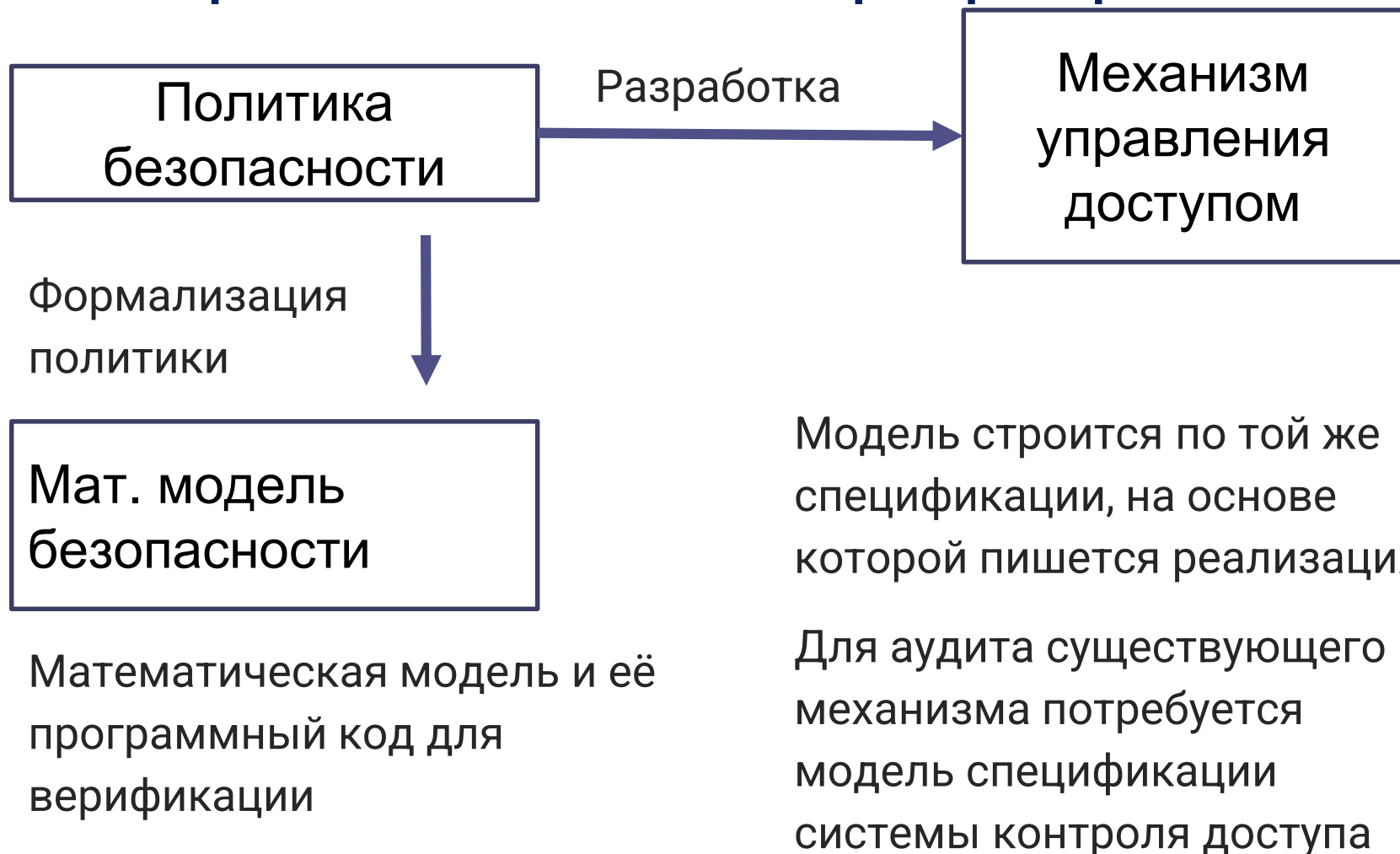
Разработка формальной спецификации

1. Разработка модели политики безопасности в строгой математической нотации (мат.модель, её основные элементы, состояния модели и правила перехода между ними)
2. Перевод математической модели на формальный язык моделирования (Event-B, Promela, ...)
3. Верификация полученной модели (доказательство консистентности, проверка свойств безопасности)

Мат. модель – спецификацией в математической нотации с комментариями и разъяснениями на естественном языке

Модель для формальной верификации - программный код

Построение модели при разработке



Примеры условий консистентности

Модель консистентна, если отвечает требованиям безопасности

- Для получения права доступа на запись в сущность, субъект-сессия должна иметь равный с сущностью уровень конфиденциальности
- Для получения права доступа на запись в сущность, субъект-сессия должна иметь более высокий уровень целостности
- Для управления доступом к сущности субъект-сессия должна иметь к ней через соответствующую текущую роль или административную роль с правом владения
- для получения субъект-сессией параметров учетной записи пользователя она либо должна функционировать от ее имени, либо иметь текущую административную роль
- субъект-сессия может удалить субъект-сессию, только обладая текущей ролью или административной ролью, имеющей к ней право доступа владения
- ...

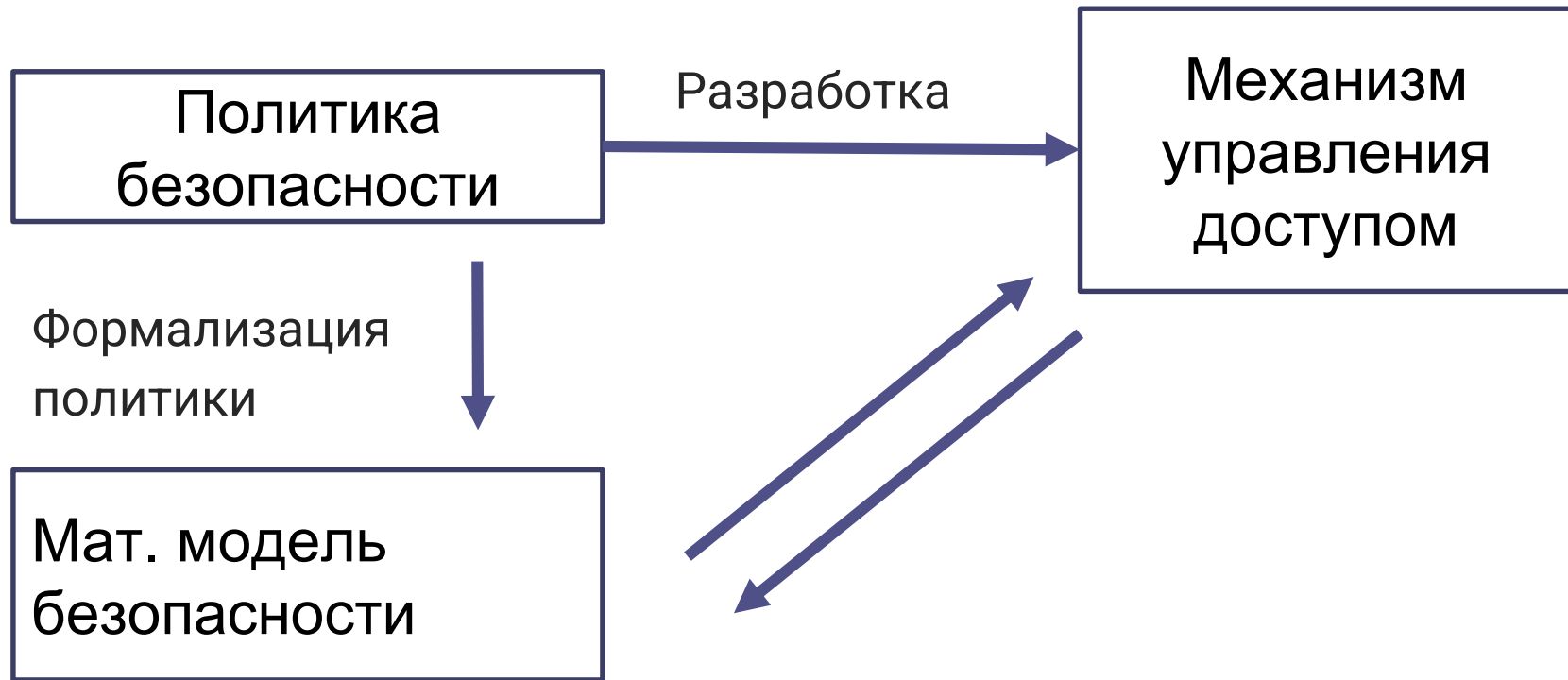
Верификация модели



Если обнаружено нарушение консистентности (при заданных правилах переходов, система перешла в небезопасное состояние), то модель корректируется

Мониторинг

Необходимо продемонстрировать, что реализация соответствует верифицированной (консистентной) модели



1. Тестовые сценарии или реальные запросы подаются на систему
2. Последовательности запросов/ответов проецируются на мат. модель

Сертификация существующего решения

Требования к безопасности

Политика безопасности



Мат. модель безопасности

Спецификация разработчиков

Механизм управления доступом



Формальная модель спецификации системы контроля доступа

Проверка соответствия

Одна модель строится на основе требований к безопасности, вторая – по спецификации к реализованному механизму

Сертификация существующего решения (пример)

ДП-модель, BLP, TG, ...
(требования регуляторов
и/или заказчика)

Мат. модель
безопасности
(Promela)

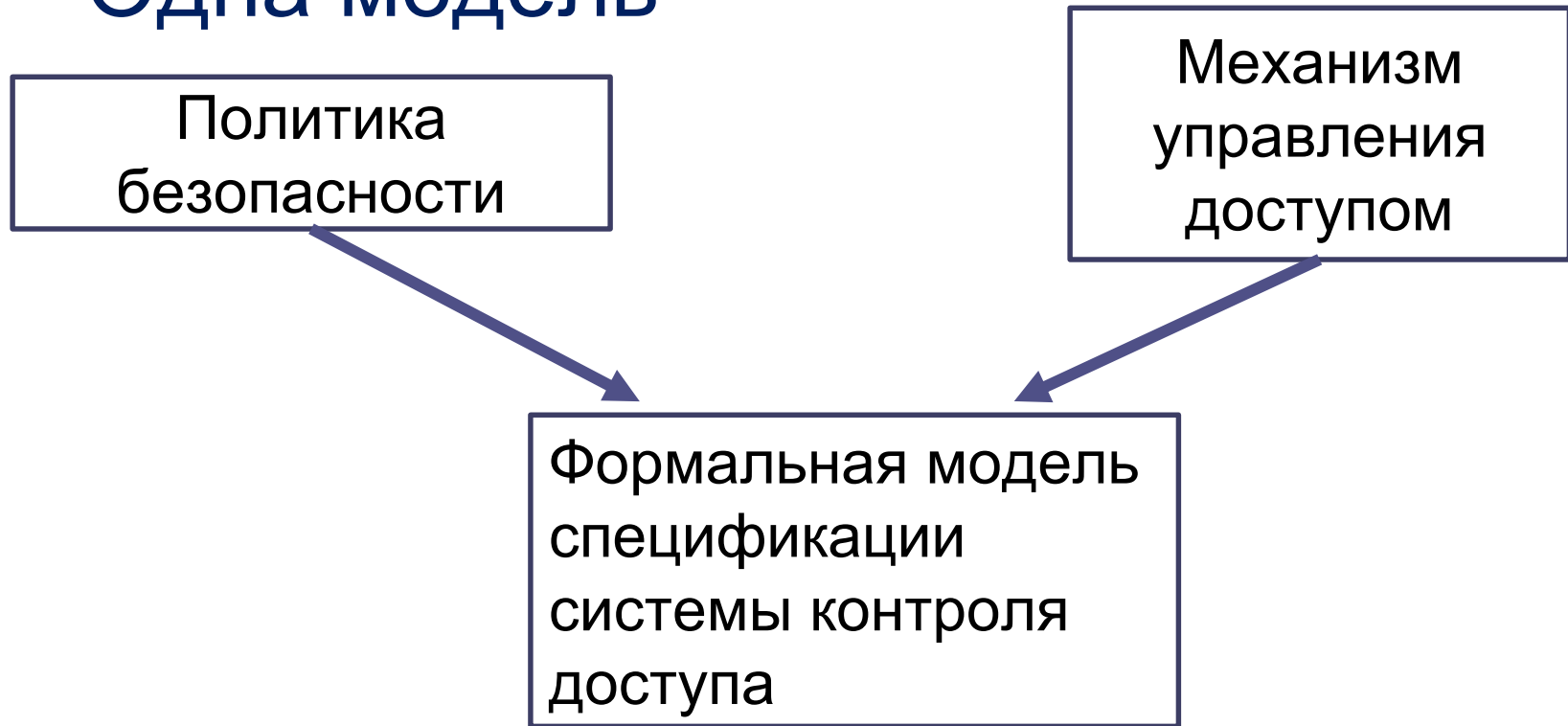
Проверка
соответствия

Спецификация
разработчиков (API ОС, web-
фреймворка, защищенной
СУБД)

Формальная модель
спецификации
системы контроля
доступа (Promela)

Вторая модель упрощает последующий мониторинг,
позволяет согласовать мат. модель безопасности с API
реального механизма

Одна модель

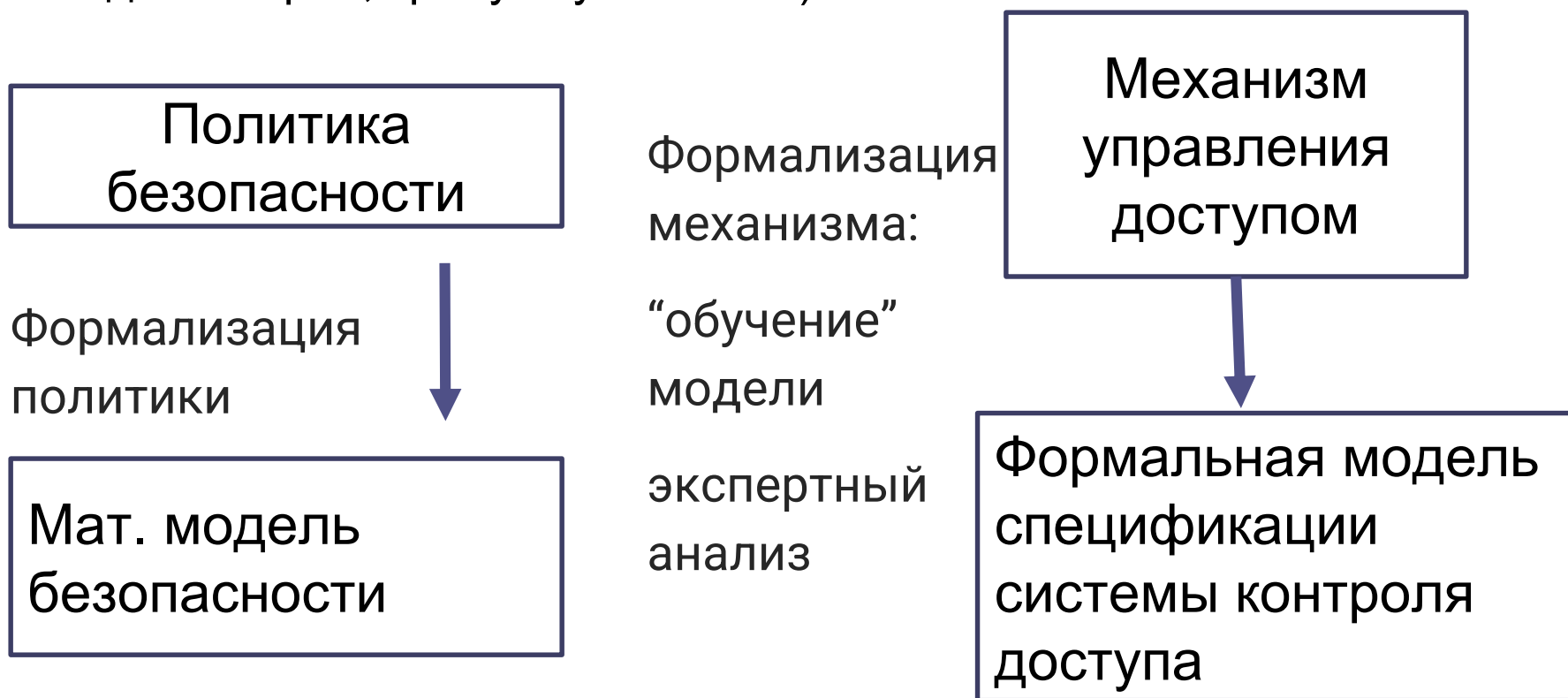


Если система достаточно проста, две эти модели можно совместить в одну, в противном случае, необходимо установить соответствия между переходами мат. модели и вызовами функций согласно спецификации

Спецификация механизма защиты

Формализуется в качестве модели для верификации

- На основе спецификации разработчиков (предыдущие слайды)
- На основе реализации (документации нет или она не достоверна, требует уточнения)



Итог

1. На основе требований к безопасности формируется математическая модель
2. Математическая модель проверяется на консистентность
3. Спецификация механизма контроля доступа моделируется и проверяется на соответствие математической модели безопасности
4. Проверенная модель механизма используется для мониторинга реализации

Процедура верификации системы контроля доступа – искусство

В зависимости от конкретной системы, требований безопасности и иных факторов, подход будет видоизменяться

Задача проверки безопасности как правило не имеет гарантированного решения и на практике приходится довольствоваться достаточно убедительной демонстрацией

Лабораторная работа

Цель: реализовать механизм управления доступом для выбранной компьютерной системы (КС)

Этапы выполнения.

1. Выбрать или реализовать КС (можно взять существующую)
2. Построить и обосновать модель безопасности для заданной КС
3. Разработать и реализовать выбранный механизм контроля доступа

Варианты компьютерной системы

- Файловый менеджер
- СУБД
- Web-приложение/сервер
- Микросервисная архитектура
- Другие варианты по согласованию с преподавателем

Сложность проекта

1 человек: простой механизм контроля доступа (дискреционный, мандатный или ролевой)

2 человека: комбинированный механизм контроля (MAC + DAC, RBAC+TBAC, ABAC с полноценной политикой, хотя бы 1-2 атрибута каждого типа и связанные с ними предикаты)

3 человека: предыдущий пункт + проработка тестовых сценариев и мониторинг безопасности

4 человека: по согласованию с преподавателем

Этапы выполнения лабораторной

1 неделя: состав группы, общая идея проекта, планируемые механизмы контроля

Результат: Запись на страницу курса в LMS

2 неделя: проектирование политики безопасности

Результат: согласование с преподавателем (на практиках)

3-5 недели: программная реализация, отладка и тестирование

6-7 недели: защита проекта с презентацией

Содержание презентации

- Архитектура защищаемого приложения, выделение в нём субъектов и объектов
- Модель (политика) безопасности
- Демонстрация программной реализации
- Тестирование (и мониторинг)